银盾智行

面向个人银行业务的安全可信智能体

安全自评报告

赛道	国内赛道 银行 AI 智能体
版本	1.0
作者	张龙龙、段慧林
日期	2026-10-27

自评范围与结论

本报告评估银盾智行比赛 Sandbox 与单机 Docker 部署中的身份认证、权限分级、Agent Tool 安全、受保护写操作、Prompt Injection 与幻觉防护、审计和异常处理。

在当前比赛范围内，资金、卡片状态、订阅取消和理财购买均经过模型外的确定性控制链。模型只能提出 Tool Call；所有写类 prepare_* Tool 只创建操作单，独立确认与 FINAL_GUARD 通过后，领域 Service 才能修改数据库。权限或风险检查失败时，系统停止执行并保存可解释原因。

本自评不构成渗透测试、等保、PCI DSS、银行生产准入或其他合规认证。真实 MFA、密钥托管、集中审计、多实例一致性、通用限流和真实模型红队仍属于生产化工作。

评估结论	结果
模型直接修改银行数据	不允许；模型无数据库凭据，最终写 Service 不在 Tool Registry
Tool 可见性作为安全边界	不采用；Gateway 使用签名 Allowed Tool Set 在执行端再次验证
高风险二次确认	已实现独立确认、AAL1/AAL2、过期、单次消费和最终复核
越权保护	服务端 Principal 所有权查询；他人和不存在资源统一 404
允许与拒绝解释	reason code、Evidence、Tool Audit、Risk/Operation Audit
生产可用性	未达到；见已知风险清单

受保护资产与信任边界

资产或输入	信任判断	处理方式
服务端 Principal	认证后条件可信	userId、角色和 AAL 只从会话读取，每次请求重新构造上下文
MySQL 业务事实	条件可信	所有权查询、版本检查、悲观锁和事务提交
LLM 输出与 Tool 参数	不可信	最小 schema、Allowed Set、Registry、参数和语义校验
用户输入与对话历史	不可信	长度和轮次限制，不作为权限事实

资产或输入	信任判断	处理方式
Tool Result 与业务文本	不可信数据	转换为 Evidence 后回送模型；不能直接授权或执行，后续提议仍须经过 Allowed Set 与 Gateway
前端 ID 和确认请求	不可信	owner、challenge、expiry、AAL、hash 和状态重验
Redis	可用性依赖	只保存会话与短时 AAL；不可用时认证失败，不降级放行

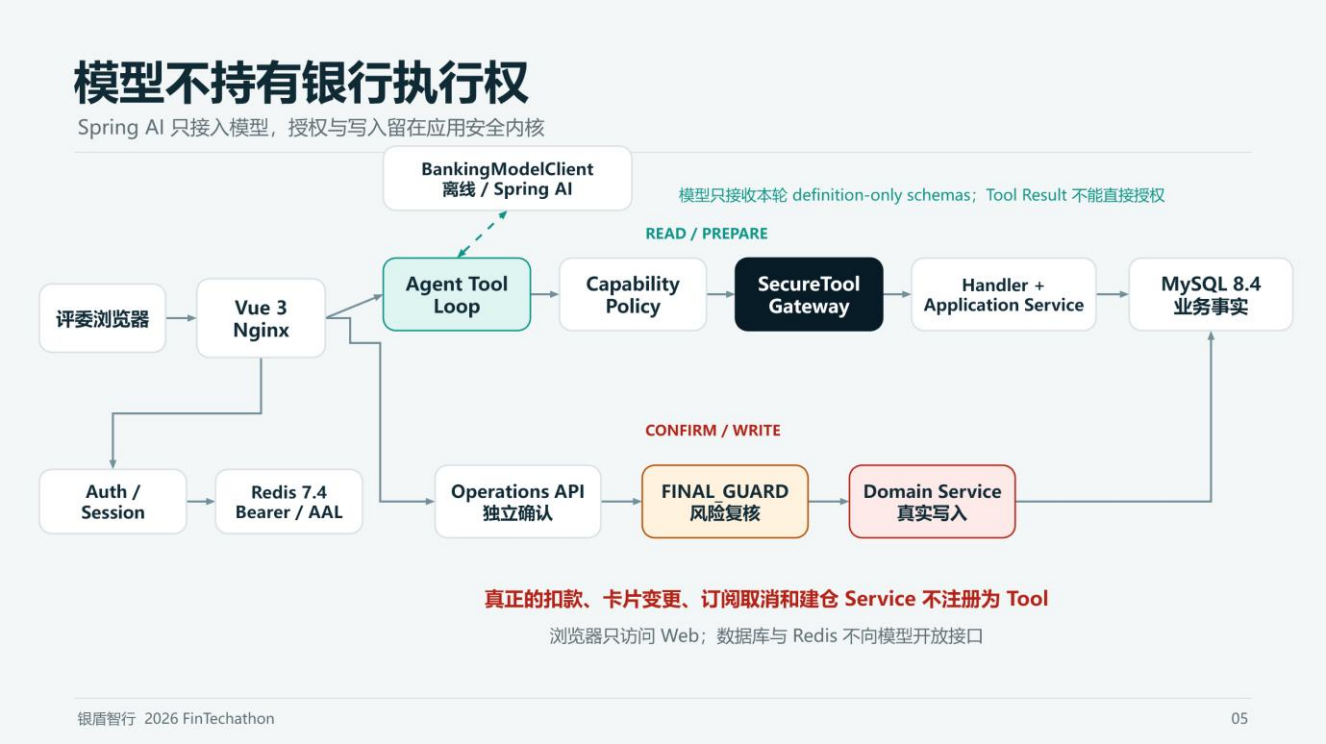


图 1 模型与银行执行内核之间的信任边界

认证与权限分级

会话认证

登录成功后，服务端生成 256 bit 不透明 bearer token。Redis 仅保存 token 的 SHA-256 key 和会话数据，默认 TTL 为 2 小时。logout 删除会话，原 token 再次访问返回 401。锁定账号不能登录。当前已建立的会话不会在每次请求重新检查用户 LOCKED 或 DISABLED 状态，生产应增加实时状态校验或集中 revoke。

角色模型

角色	权限范围	限制
CUSTOMER	本人账户、流水、卡片、收款人、订阅、产品和 Agent；创建本人待确认操作	不能访问其他用户资源，不能 reset Sandbox
DEMO_ADMIN	唯一专属权限是本地演示环境的 Sandbox reset	无 CUSTOMER Tool capability，也不拥有客户银行资源

Spring Security 只对登录、健康与有限错误诊断入口，以及非 prod 的 API 文档放行；其余接口均要求认证。Sandbox 组件使用 !prod 与 dev、test、offline-demo 的组合 profile；reset endpoint 还要求 DEMO_ADMIN。

AAL 分级

等级	取得方式	允许操作	有效期
未认证（非 AAL 枚举）	未登录	登录、健康与有限诊断入口，以及非 prod 文档入口	无会话
AAL1	用户名密码登录	本人查询和创建待确认操作	会话默认 2 小时
AAL2	Sandbox 固定码 step-up	大额或不可信收款人、理财购买、卡片解冻和放宽控制	默认 5 分钟并绑定原会话

prod profile 禁止固定码 step-up，即使误混入 offline-demo profile 也会降级遗留 AAL2 会话。当前 AAL2 仅用于比赛 Sandbox，不是生产 MFA。

对象所有权

Controller 和 Application Service 根据 BankingPrincipal.userId 查询资源。Tool schema 不提供 userId、role、AAL、snapshot 或 requestId 等授权字段；Idempotency-Key 只可由 HTTP header 或服务端上下文提供，取 hash 后用于重放控制，不参与身份授权。Alice 请求 Bob 的账户、卡片、订阅或 operation 时，系统按与不存在资源相同的 404 处理，减少资源枚举。

Capability 与 Tool 安全

每轮最小权限

Agent 根据当前用户消息选择候选 Tool。Capability Policy 按服务器 Principal 的角色与能力、Registry 和候选集合决定快照成员，并把 user、role、AAL、requestId 与 policyVersion 绑定进 AllowedToolSetSnapshot。AAL1 可以创建 requiredAal 为 AAL2 的待确认操作，但最终确认必须满足 requiredAal。快照最多接受 20 个候选，默认有效期 60 秒，并使用进程内 HMAC-SHA256 key 签名。

快照绑定项	用途
snapshotId 与 requestId	防止跨请求重用
userId 角色 AAL	防止跨用户、角色或认证强度错绑
policyVersion 与过期时间	拒绝旧策略或过期快照
name version capability accessMode	精确成员资格和执行模式
schemaVersion acceptedArgs descriptorDigest	发现 Tool 元数据漂移和参数面变化
HMAC signature	检测快照内容篡改

模型侧与执行侧双重门禁

1. SpringAiToolSchemaCatalog 只把 snapshot.allowedTools 转换为本轮 definition-only Tool Schema。
2. 模型输出只视为提议。ReadOnlyBankingAgent 把每个调用交给 SecureToolGateway。
3. Gateway 验证签名快照、当前上下文和精确成员资格，再查 ExplicitToolRegistry。
4. Gateway 比较 descriptor digest 和 access mode，随后完成参数前置校验；前置门禁失败时不进入 Handler。
5. Handler 进入 Application Service 后再做资源所有权、业务权限和风险检查；拒绝由 Gateway 归一为 DENY 或 ERROR 审计。

application.yml 显式设置 spring.ai.tools.resolution.fallback.enabled=false 和 spring.ai.chat.client.tool-calling.enabled=false。Spring AI 请求还设置 internalToolExecutionEnabled(false)，callback 如果被框架调用会立即抛错。

Tool Registry

Registry 由构造器显式注册 17 个 Tool，使用精确 name 和 version，重复 ToolId 在启动时失败。写类 Tool 只有 prepare_transfer、prepare_card_status_change、prepare_card_controls_change、prepare_subscription_cancellation、prepare_wealth_purchase。Registry 不包含 execute_transfer 或其他最终写执行器。

参数与资源校验

- ToolId 必须满足格式、长度和版本规则；未知、混淆或控制字符标识拒绝。
- JSON schema 仅允许声明字段，未知字段和错误类型拒绝。当前解析器未显式拒绝重复 JSON key，此项列入已知风险。
- Bean Validation 和语义校验限制日期范围、分页、金额、币种、枚举和字符串长度。
- 所有资源 ID 在 Application Service 中再次按 Principal 所有权解析。
- Handler 不能直接访问 Repository；ArchUnit 同时禁止 Agent 访问 Repository、Handler 和 Registry。

受保护写操作

准备阶段

prepare Tool 在通过 Gateway 后保存 operation_request、risk_decision、operation_audit 和 idempotency_record；只有风险允许时才生成一次性 confirmation_challenge。它可以返回 AWAITING_CONFIRMATION、AWAITING_STEP_UP 或 DENIED，但不能改变余额、卡状态、订阅状态或持仓。

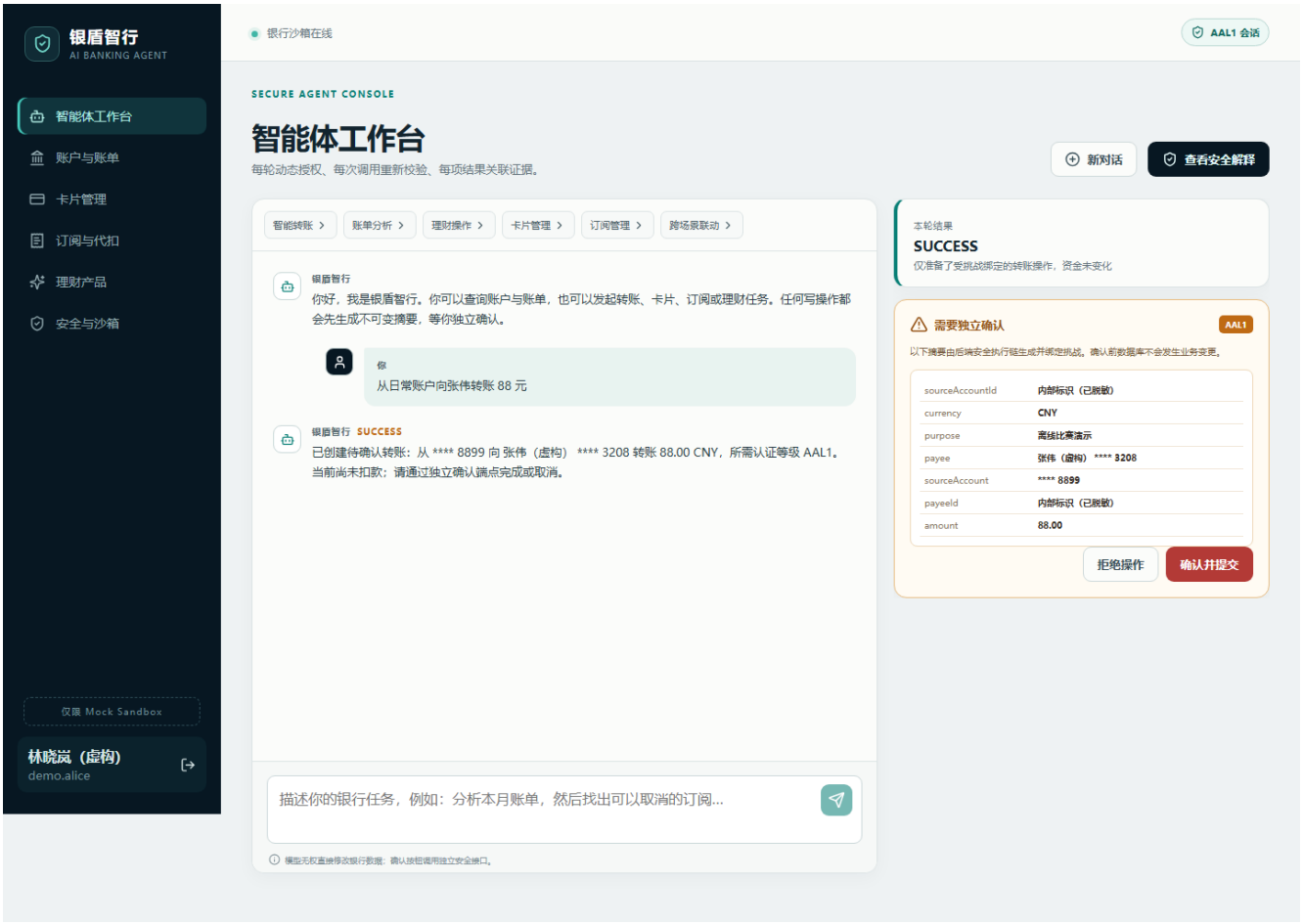


图 2 PREPARE 成功后页面显示参数摘要和待确认状态

独立确认与最终复核

用户通过 POST /api/v1/operations/{operationId}/confirm 独立确认。请求体只允许 challengeId 和 confirmed，不接受金额、收款人、目标状态或产品等业务字段。Service 在同一事务中执行以下步骤。

1. 悲观锁定当前用户拥有的 operation 和 challenge。
2. 检查 operation 状态、challenge 绑定、过期时间、单次消费和 required AAL。
3. 重新计算并比较 canonical args hash 与 display summary hash。
4. 锁定 operation、challenge、user 及相关可变核心资源；重新读取适当性与风险画像。对卡、订阅和产品检查版本，对账户重验当前状态、币种与余额。
5. 重新运行 FINAL_GUARD 风险规则。
6. 执行领域变更，写回执或变更历史，并与审计记录原子提交。

风险规则

场景	需要 AAL2	主要拒绝条件
转账	金额不低于 10000 CNY，或收款人不可信或从未使用	余额不足、日限额、10 分钟速度规则、账户或币种状态
卡片	解冻、开启线上或境外、提高限额	非法状态转换、限额错误、资源版本变化
订阅	当前版本不固定要求 AAL2	非 ACTIVE 或 PAUSED、不可取消、资源版本变化
理财	所有购买	风险不匹配、测评过期、停售、起购或递增金额、余额、适当性绑定

幂等 重放与 TOCTOU

幂等记录以 userId、scope 和 idempotency key hash 唯一。同键同参返回原 operation 或 receipt，同键异参拒绝。challenge 只能消费一次；并发确认依靠 operation 悲观锁和结果表 operation_id 唯一约束。卡片与订阅使用 expectedVersion 检测状态漂移；转账和理财在确认时重新读取余额、状态、币种和风险事实。

Prompt Injection 与幻觉

防御原则

系统不把注入关键词检测当作最终边界。即使模型完全遵从恶意指令，隐藏 Tool 仍不在本轮 schema 中，Gateway 仍会验证签名快照和成员资格；伪造资源在 owner-scoped Service 失败；最终写 Service 不存在于 Registry。模型也没有 SQL、文件、任意网络或代码执行 Tool。

Grounding Guard

GroundedAnswerService 收集成功 Evidence 和确定性分析结果中的数字，并逐项核对模型回答中的关键数字。prepare_* 成功后系统直接生成确定性的等待确认答复；无 PREPARE 时，有限规则拦截部分写成功措辞。最终 SUCCEEDED 由独立 confirm API 的服务端回执证明，不再交给模型判定。该实现不能证明所有定性语句均由 Evidence 蕴含。

资源消耗与故障

控制或故障	安全行为
模型轮次与 Tool 调用	最多 5 轮、每轮 4 次、总计 12 次；重复调用拒绝
输入与上下文	消息 4000 字符、上下文 65536 字符、回答 8000 字符
模型或 Tool 超时	返回受控错误，不让模型补造结果
Redis 不可用	登录和会话失败，不降级为匿名授权
MySQL 不可用	业务失败，不使用缓存余额执行
审计事务失败	写事务回滚且不返回未审计成功；Agent 路径返回受控错误，直接 Tool API 可能返回 5xx

审计与隐私

审计内容

记录	主要字段	当前用途
Tool Security Audit	request、snapshot、user、Tool、version、decision、reason、args hash、duration	证明 Gateway 已执行参数、成员和策略检查
Risk Decision	operation、phase、outcome、policy、input hash、reason codes	说明 PRE_CONFIRM 与 FINAL_GUARD 的风险结论
Operation Audit	stage、outcome、reason、timestamp	记录准备、确认、拒绝和最终执行
业务回执或历史	operation_id、before/after、completed_at	证明真实业务是否提交

Tool audit 只保存 JSON 对象键排序后的参数 SHA-256，不保存原始参数。HTTP 请求日志不记录 query、body、Authorization、密码、AAL2 code 或 Prompt。账户和卡片使用掩码。当前审计数据库由普通数据库管理员可修改，不能宣称防篡改或 WORM。

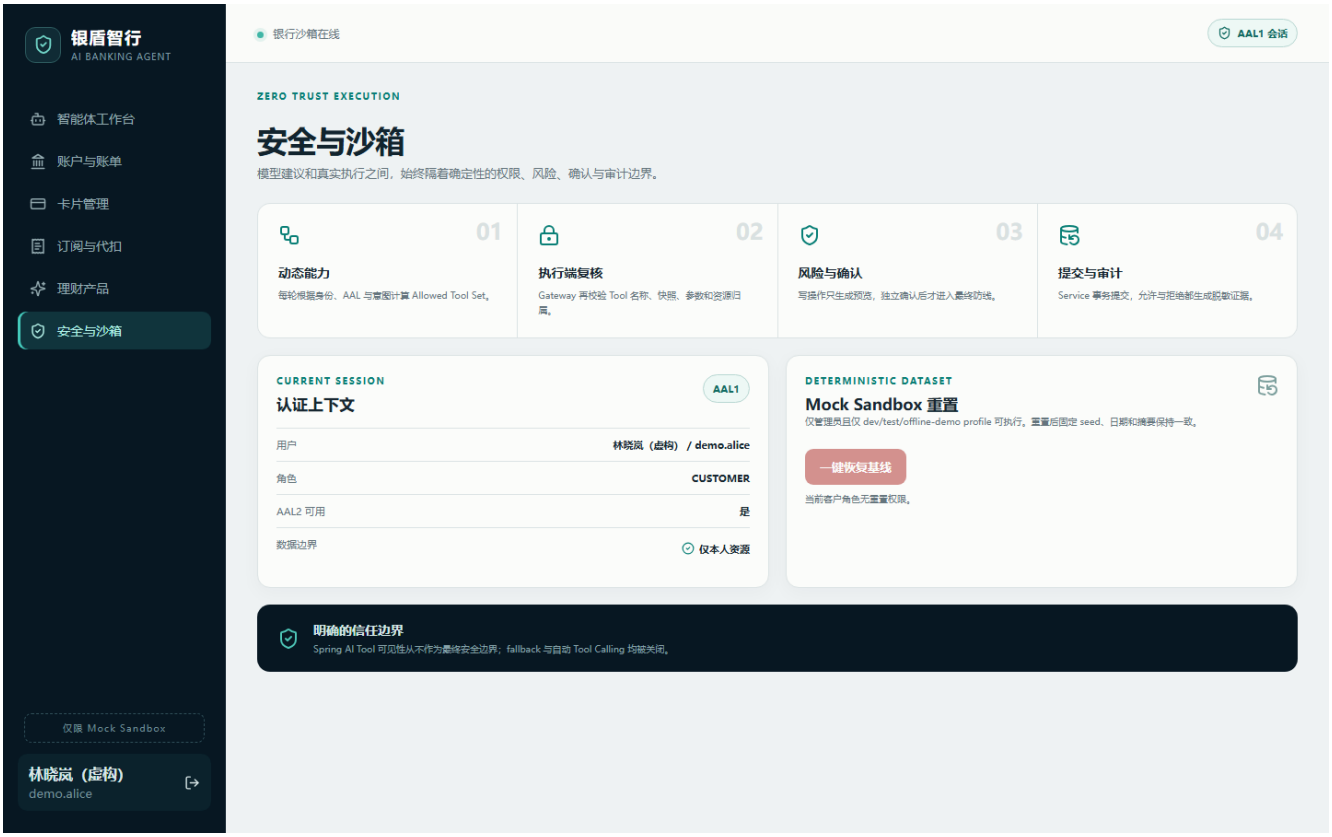


图 3 安全页面说明动态能力 执行端复核 风险确认和审计边界

安全测试证据

以下结果来自 2026-09-11 的交付记录和当前 surefire report。

测试层	覆盖性质	结果
SecureToolGatewayTest	未暴露 Tool、畸形 ID、参数注入、错绑、过期与篡改快照、审计故障	通过
ReadOnlyBankingAgentTest	注入、提权、越权资源、幻觉 Tool/版本/数字、循环、超时和 Provider 故障	通过
BankingFoundationIntegrationTest	认证、所有权、Capability、确认、AAL2、幂等、TOCTOU、并发、四类写操作	通过
ArchitectureRulesTest	Agent/Tool 到 Repository，Agent 到 Handler/Registry 的禁止依赖	通过
ToolSafetyConfigurationTest	fallback 与自动 Tool Calling 均关闭	通过
总计	24 个后端测试套件，162 项测试	0 失败 0 错误 0 跳过

acceptance.ps1 在真实 Docker API 上验证固定 reset、AAL1、本人资源、越权 404、只读与跨场景 Agent、PREPARE 零业务副作用、注入零 Tool、logout revoke 和 OpenAPI。Playwright 9 个场景使用模拟 API 验证 UI，不替代后端集成测试。默认测试不连接真实外部模型。

已知风险清单

等级	风险	建议
生产阻断	AAL2 仅为 Sandbox 固定码，prod 中禁用	接入真实 OTP、FIDO、设备绑定或交易签名，并做独立认证风控
生产阻断	Compose 使用演示凭据，MySQL 与 Redis 无 TLS 或集中密钥管理	使用 KMS 或 Secrets Manager、TLS、凭据轮换和最小网络暴露
高	缺少通用登录、API 和 Tool 限流及 WAF；/tools/execute 对已认证 CUSTOMER 可用于演示调用	生产移除或内网化直接 Tool API，增加渠道和意图策略、账户锁定与速率限制
中	Allowed Tool Set HMAC key 为进程启动时随机 key；重启会使存量短时快照 fail closed；计划、对话和 Evidence 偏单实例	使用托管密钥、轮换、共享状态和跨实例一致性协议
中	prepare 并发去重包含单 JVM synchronized；多实例可能暴露唯一键异常；expiresAt 虽已保存但查询未执行到期语义，旧 key 不会自动释放	使用数据库原子 upsert 或分布式锁，统一冲突映射，并实现 TTL 到期语义和清理
中	JSON 解析器未显式拒绝重复 key，当前采用 last value 语义	开启严格重复键检测并增加攻击测试
中	审计保存在普通数据库，不是 WORM；X-Trace-Id 与全部内部 requestId 尚未完整贯通	接入集中审计、不可变存储、签名链和统一 trace 传播
中	Grounding Guard 强校验数字，但只以有限规则覆盖部分写成功措辞；真实 LLM 尚未完成系统化红队	增加基于 Evidence 的语义核验、模型评测、Prompt Injection 红队和人工复核
中	bearer 保存在 sessionStorage，已有会话不会实时重查用户状态	采用 BFF 与 HttpOnly Cookie，每请求检查用户状态或提供集中 revoke
中	operation 和审计会保存规范业务参数；Mock 环境没有真实数据	生产采用字段级加密、最小化、脱敏、留存和删除策略
中	默认 offline-demo 不外传数据；显式启用真实 Spring AI Provider 时，用户消息、会话片段和必要 Evidence 会发送到配置的兼容端点	增加 DLP、供应商合规与地域路由评估，优先接入私有模型网关并取得用户授权

等级	风险	建议
中	模型与 Tool 超时通过 Future.cancel(true) 尽力取消，不能证明底层 JDBC 或外部 HTTP 已立即停止	同时配置驱动级超时、可取消调用和事务边界，避免超时后继续产生副作用
中	Tool Security Audit 使用 REQUIRES_NEW；外层 PREPARE 随后回滚时，可能保留 ALLOW 审计但没有对应操作单	以 invocation/operation 关联提交结果，增加对账状态或事务 outbox，明确 ALLOW 仅代表 Gateway 放行
低	适当性记录保存 account_version，但最终购买未直接比较该版本；当前通过锁定账户并重验状态、币种和余额补偿	在最终绑定校验中比较 account_version，或删除未执行语义的字段并补测试
低	check_wealth_suitability 标为 READ_ONLY 但会写适当性证据	将访问模式改名为 NO_ASSET_SIDE_EFFECT 或单独的 EVALUATION_WRITE
低	Flyway 对 MySQL 8.4 有正式测试范围警告	评估升级 Flyway 或固定受支持版本，并在升级前重跑 migration 和回归测试

自评结论

银盾智行在比赛 Sandbox 内建立了模型外的授权与执行边界。动态 Capability、签名 Allowed Tool Set、执行端二次校验、PREPARE、独立确认、AAL、最终风险复核、幂等和审计均有实现与自动化测试证据。

上述控制降低了 Prompt Injection、幻觉、越权和重复执行直接改变银行事实的风险。生产使用仍取决于真实 MFA、托管密钥、集中审计、限流、共享状态、隐私治理、真实模型红队、渗透测试和合规评审。项目在完成这些工作前只用于竞赛演示和安全机制验证。